

الوحدة 07: التهديدات والجهات المهاجمة

الجهات المهاجمة (Threat Actors)

الجهات المهاجمة هي أفراد أو مجموعات تشكل تهديداً لأمن المعلومات. تختلف في دوافعها وقدراتها:

- **APT (Advanced Persistent Threat)**: مجموعات متقدمة ترعاها دول. تهاجم أهدافاً محددة (بنية تحتية، حكومة). هادئة، طويلة الأمد، شديدة التطور. مثال: (APT29 Cozy Bear).
- **Hactivists**: قراصنة بدوافع سياسية أو اجتماعية. هدفهم لفت الانتباه لقضية ما. يستخدمون هجمات DDoS وتشويه المواقع. مثال: Anonymous.
- **Insider Threat**: تهديد من داخل المؤسسة (موظف، مقاول). إما متعمد (موظف ساخط) أو غير متعمد (إهمال). الأصعب في الاكتشاف.
- **Script Kiddies**: مبتدئون يستخدمون أدوات جاهزة. دوافعهم عادة التسلية أو الاستعراض. خطرهم محدود.
- **Cyber Criminals**: مجرمون بدافع مالي. يستخدمون Ransomware، الاحتيال، سرقة البيانات. مثال: مجموعات Ryuk، REvil.
- **Nation-State**: دول تدعم عمليات هجومية سيبرانية للتجسس أو التخريب أو الحرب السيبرانية.

الهندسة الاجتماعية (Social Engineering)

الهندسة الاجتماعية تعتمد على خداع البشر بدلاً من اختراق الأنظمة. أشهر أنواعها:

- **Phishing**: رسالة بريد إلكتروني مزيفة تبدو من مصدر موثوق. الهدف سرقة بيانات الدخول أو تثبيت برمجيات خبيثة.
- **Spear Phishing**: Phishing موجه لشخص معين باسمه ومنصبه.
- **Whaling**: Phishing يستهدف كبار المسؤولين (CEO، CFO).
- **Smishing / Vishing**: عبر SMS أو المكالمات الصوتية.
- **Pretexting**: اختلاق سيناريو كاذب للحصول على معلومات.
- **Tailgating**: شخص غير مصرح له يدخل منطقة آمنة خلف شخص مصرح له.
- **Shoulder Surfing**: النظر من فوق الكتف لسرقة كلمة المرور.
- **Baiting**: ترك USB مصاب بالفيروس في مكان عام ليقوم أحدهم بتوصيله.

مثال: تحليل رسالة Phishing

رسالة احتيالية نموذجية:

الموضوع: تنبيه أمني عاجل - تم اختراق حسابك
من: support@security-alert-xyz.com
إلى: user@example.com

عزيزي المستخدم،
نلاحظ نشاطاً مشبوهاً على حسابك. يرجى النقر على الرابط أدناه
لتأكيد هويتك وتجنب إغلاق الحساب:
<http://fake-login-page.com/verify>
شكراً لك،
فريق الأمن

علامات الاحتيال (Red Flags):

- عنوان البريد الإلكتروني مشبوه (ليس النطاق الرسمي للبنك أو الخدمة).
- الرابط يؤدي إلى موقع غير موقع الخدمة الأصلي (تحقق بالوقوف على الرابط).
- لغة تهديدية (عاجل، سيتم إغلاق الحساب) لدفعك للتصرف بسرعة.
- طلب تأكيد معلومات شخصية - الشركات الحقيقية لا تطلب ذلك عبر البريد.

مؤشرات الاختراق (Indicators of Compromise - IoCs)

IoCs هي أدلة أو آثار تدل على أن النظام قد تم اختراقه. تساعد فرق الاستجابة في اكتشاف الهجمات وتحليلها. أنواعها:

- **IoCs متعلقة بالشبكة:** عناوين IP مشبوهة، نطاقات غير معروفة، حركة مرور غير طبيعية.
- **IoCs متعلقة بالملفات:** هاش ملفات خبيثة (SHA-256)، أسماء ملفات غير معروفة.
- **IoCs متعلقة بالنظام:** عمليات غير معروفة (Processes)، تغييرات في التسجيل (Registry)، حسابات جديدة.
- **IoCs متعلقة بالسلوك:** محاولات دخول فاشلة متكررة، استخدام صلاحيات غير معتاد، اتصالات صادرة غير مبررة.

تحليل الشبكة باستخدام netstat -ano

```
netstat -ano
```

يعرض جميع الاتصالات النشطة على الجهاز مع PID (معرف العملية). الأعمدة:

- **Proto:** البروتوكول (TCP/UDP).
- **Local Address:** المنفذ المحلي (مثال: 0.0.0.0:443 يعني أن الخادم يستمع على المنفذ 443).
- **Foreign Address:** العنوان البعيد المتصل به.
- **State:** حالة الاتصال (LISTENING، ESTABLISHED، TIME_WAIT).
- **PID:** رقم العملية.

تحليل عملي - البحث عن اتصال مشبوه:

```
# فقط ESTABLISHED عرض الاتصالات  
netstat -ano | findstr ESTABLISHED  
  
# بعملية معينة PID ربط  
tasklist | findstr 1234
```

إذا رأيت اتصالاً ESTABLISHED بعنوان IP غير معروف في دولة غير متوقعة، قد يكون هذا IoC يشير إلى وجود Backdoor أو C2 ((Command & Control.

(Quick Quiz (MCQ

1. APT stands for :

- a) Automatic Penetration Test
- b) Advanced Persistent Threat
- c) Application Protocol Transfer
- d) Active Phishing Toolkit

Answer: b

2. Which attack relies on manipulating people rather than technology ?

- a) DDoS
- b) Social Engineering
- c) Brute Force
- d) SQL Injection

Answer: b

3. A phishing attack targeted specifically at executives is called :

- a) Spear Phishing
- b) Whaling
- c) Vishing
- d) Baiting

Answer: b

4. IoCs stand for :

- a) Internet of Connected Systems
- b) Indicators of Compromise
- c) Internal Operations Center
- d) Incident of Cyber Security

Answer: b

5. Which command displays active network connections on Windows ?

a) ping

b) tracert

c) netstat -ano

d) ipconfig

Answer: c